

UNIVERSITÀ
DEGLI STUDI DI BARI
ALDO MORO

DIPARTIMENTO DI INFORMATICA

CORSO DI LAUREA IN INFORMATICA

TESI DI LAUREA
IN
METODI AVANZATI DI PROGRAMMAZIONE

Sintesi di un algoritmo per Windows PE malware detection

RELATRICE:
Prof.ssa Annalisa Appice

LAUREANDO:
Domenico Bianchini

CORRELATRICE:
Prof.ssa Giuseppina Andresini

ANNO ACCADEMICO 2025 - 2026

Indice

1 Introduzione 1
1.1 Contesto e motivazioni 1
1.2 Obiettivi della tesi 2
1.3 Struttura della tesi 2

2 Malware e file Windows PE 4
2.1 Il formato Windows PE 4
2.2 Malware e tecniche di rilevamento 5
2.3 Malware e tecniche di rilevamento 6

3 Scoperta di Windows PE malware 7
3.1 Conversione di file PE in immagini 7
3.2 ResNet per classificazione di immagini 7

4 Validazione empirica 8
4.1 Dataset 8
4.2 Set-up e metriche 8
4.3 Risultati 8

5 Conclusioni e sviluppi futuri 9

Bibliografia 10

Capitolo 1

Introduzione

1.1 Contesto e motivazioni

La sicurezza informatica rappresenta un aspetto sempre più rilevante in un contesto in cui sistemi e servizi digitali sono utilizzati in numerosi ambiti della vita quotidiana. Tra le principali minacce alla sicurezza dei sistemi informatici rientrano i malware, software sviluppati con l'obiettivo di compiere azioni dannose o non autorizzate, che possono compromettere il corretto funzionamento dei sistemi e mettere a rischio i dati in essi contenuti. La diffusione dei malware e la loro continua evoluzione rendono il loro rilevamento un problema di particolare importanza nell'ambito della cybersecurity.

Esistono diversi approcci per il rilevamento dei malware, fra cui i metodi tradizionali basati sul riconoscimento di firme note e sull'analisi delle caratteristiche del software; tuttavia, la continua comparsa di nuove varianti di malware e l'utilizzo di tecniche che ne rendono più difficile l'individuazione hanno portato alla ricerca di approcci alternativi. In particolare, negli ultimi anni hanno assunto particolare importanza le tecniche basate su Machine Learning e Deep Learning, che permettono di individuare più efficacemente anche nuove varianti di malware, superando alcuni dei limiti dei metodi tradizionali.

L'utilizzo del Deep Learning consente, inoltre, di analizzare i dati attraverso diverse forme di rappresentazione, in particolare la rappresentazione visuale dei file malware, ottenuta trasformando le informazioni contenute nei file binari in immagini. In questo modo è possibile applicare tecniche e modelli di Deep Learning

per la classificazione delle immagini, con l'obiettivo di distinguere file malevoli da file legittimi.

1.2 Obiettivi della tesi

L'obiettivo di questo lavoro di tesi è la sintesi di un algoritmo in grado di classificare i file Windows Portable Executable (PE) come malevoli o benigni, rappresentandoli prima sotto forma di immagini e utilizzando successivamente un modello di Deep Learning per la loro classificazione.

In particolare, questo lavoro analizza e confronta tre diverse strategie per la conversione dei file PE in immagini, ossia LINEAR, ZIGZAG e SERPENTINE, che si differenziano in base al tipo di mapping utilizzato per costruire l'immagine. Per ciascuna strategia vengono confrontate sia immagini RGB sia grayscale, generate secondo due diverse configurazioni a dimensione fissa oppure variabile in base alla dimensione del file PE. Le immagini ottenute vengono poi utilizzate per addestrare e valutare un modello ResNet-50, con l'obiettivo di distinguere i file malevoli da quelli benigni.

Il confronto dei risultati ottenuti dalle diverse configurazioni e strategie di mapping permette infine di valutarne le prestazioni e individuare quale configurazione risulti più efficace nella classificazione dei file PE.

1.3 Struttura della tesi

La tesi è organizzata in cinque capitoli, il primo dedicato all'introduzione del lavoro, al suo contesto, alle motivazioni e agli obiettivi.

Il Capitolo 2 descrive il formato Windows Portable Executable (PE), analizzandone le principali caratteristiche, e introduce il concetto di malware e le principali tecniche utilizzate per il loro rilevamento.

Il Capitolo 3 descrive il processo di conversione dei file PE in immagini, presentando le diverse strategie di mapping e le configurazioni utilizzate per la loro rappresentazione, e l'utilizzo di ResNet per la successiva classificazione.

Il Capitolo 4 è dedicato alla validazione empirica del lavoro e descrive il dataset utilizzato, il set-up sperimentale e le metriche adottate per la valutazione. Vengono

inoltre analizzati e confrontati i risultati ottenuti dalle diverse configurazioni utilizzate, con lo scopo di individuare quella con le migliori prestazioni, ovvero quella più efficace nella classificazione dei file PE.

Infine, il Capitolo 5 riassume i principali risultati ottenuti e presenta le conclusioni del lavoro e i possibili sviluppi futuri.

Capitolo 2

Malware e file Windows PE

2.1 Il formato Windows PE

Il Portable Executable (PE) è il formato utilizzato nei sistemi Windows per i file `.exe`, `.dll` e altre tipologie di file eseguibili. Inizialmente progettato come formato eseguibile standard per i sistemi Windows, il formato PE, fin dalla sua introduzione, ha subito diverse modifiche, anche in seguito al passaggio ai sistemi Windows a 64 bit.

La struttura di un file PE contiene le informazioni necessarie al sistema operativo Windows per caricare e gestire il codice eseguibile. Oltre al codice da eseguire, un file PE contiene infatti metadati e altre informazioni organizzate secondo una struttura ben definita, la cui conoscenza riveste un ruolo importante nell'ambito dell'analisi dei malware.

In particolare, la struttura di un file PE è organizzata in tre parti principali [1], come mostrato nella Figura 2.1:

- **Header**: contiene le informazioni principali relative al file PE e al suo caricamento in memoria. L'header è a sua volta suddiviso nelle seguenti parti:
  - **DOS Header**: rappresenta la parte iniziale del file PE e contiene informazioni relative al formato DOS. Contiene inoltre un riferimento che indica la posizione iniziale del PE Header;
  - **DOS Stub**: viene utilizzato per visualizzare un messaggio che indica se il programma può essere eseguito o meno in modalità DOS;

  - **NT Header**: contiene le principali informazioni relative al file PE ed è a sua volta suddiviso in:
    * **PE Signature**: identifica il file come Portable Executable;
    * **COFF File Header**: contiene informazioni sulle caratteristiche del file e sulle sezioni presenti;
    * **Optional Header**: contiene informazioni utilizzate durante il caricamento del file in memoria, tra cui il punto di ingresso del programma.

- **Tabella delle sezioni**: descrive le caratteristiche delle diverse sezioni presenti nel file e contiene le informazioni necessarie per mapparle in memoria e indicare se ciascuna sezione è di sola lettura oppure scrivibile;

- **Sezioni**: contengono il codice e i dati del file PE. Tra le sezioni comunemente presenti si trovano:

  - `.text`: contiene il codice eseguibile;
  - `.data`: contiene le variabili globali e statiche inizializzate;
  - `.bss`: contiene le variabili globali e statiche non inizializzate;
  - `.rsrc`: contiene le risorse utilizzate dal programma, come icone, immagini, stringhe e finestre di dialogo;
  - `.reloc`: contiene i dati necessari alla rilocazione del programma;

2.2 Malware e tecniche di rilevamento

L'header riveste un ruolo importante nella classificazione dei malware, dato che le informazioni in esso contenute sono risultate tra quelle che contribuiscono maggiormente al processo di classificazione [3].

L'analisi della struttura delle sezioni può essere utile anche nell'ambito del rilevamento dei malware, dato che il codice malevolo può essere nascosto all'interno di sezioni insolite oppure possono essere aggiunte ulteriori sezioni con l'obiettivo

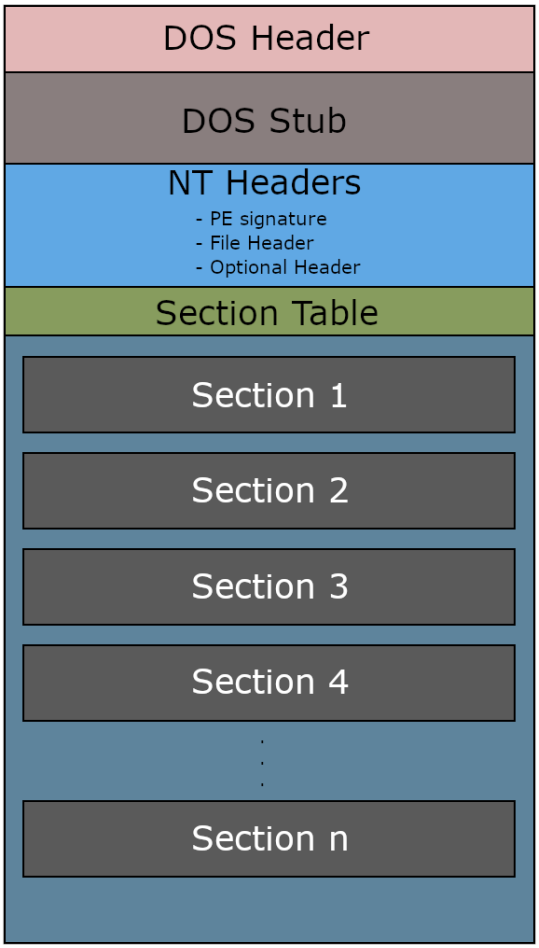


Figura 2.1: Struttura generale di un file PE, tratta da [2]

di rendere più complessa l'analisi del file. Inoltre, i file malware possono presentare anomalie nella struttura e nelle caratteristiche del formato PE rispetto ai file benigni, rendendo queste informazioni rilevanti per il loro rilevamento [4].

2.3 Malware e tecniche di rilevamento

Capitolo 3

Scoperta di Windows PE malware

3.1 Conversione di file PE in immagini

3.2 ResNet per classificazione di immagini

Capitolo 4

Validazione empirica

4.1 Dataset

4.2 Set-up e metriche

4.3 Risultati

Capitolo 5

Conclusioni e sviluppi futuri

Bibliografia

[1] Microsoft. PE format. `https://learn.microsoft.com/en-us/windows/win32/debug/pe-format`.

[2] Faiza Babar Khan, Muhammad Hanif Durad, Asifullah Khan, Farrukh Aslam Khan, Sajjad Hussain Chauhdary, and Mohammed Alqarni. Detection of data scarce malware using one-shot learning with relation network. *IEEE Access*, 11:74438–74457, 2023.

[3] Yunchun Zhang, Jiaqi Jiang, Chao Yi, Hai Li, Shaohui Min, Ruifeng Zuo, Zhenzhou An, and Yongtao Yu. A robust CNN for malware classification against executable adversarial attack. *Electronics*, 13(5):989, 2024.

[4] Jinrong Bai, Junfeng Wang, and Guozhong Zou. A malware detection scheme based on mining format information. *The Scientific World Journal*, 2014(1):260905, 2014.

Ringraziamenti

Lorem ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit esse cillum dolore eu fugiat nulla pariatur. Excepteur sint occaecat cupidatat non proident, sunt in culpa qui officia deserunt mollit anim id est laborum.